# Security Fundamentals Report

By William Riseborough, Muhammad Shumel, Amin Hassan, Patryk Puczek

Introduction..... 2

Multifactor Authentication: The Categories, Effectiveness and Trade-offs..... 3

The Categories of authentication factors..... 3

Analysing 2FA/MFA Implementation ..... 3
Evidence of Effectiveness ..... 4
Security Guidance ..... 4
Public Wi-Fi ..... 5
Public Wi-Fi statistics and introduction ..... 5
Preventative Measures ..... 5
Man-in-the-Middle Attacks ..... 6
Phishing/Social engineering ..... 6
Defining phishing ..... 6
Difference between Phishing and other forms of Phishing: ..... 7
Defining Social engineering: ..... 7
Methods of Attack (Phishing) ..... 7
Methods of Attack (Social engineering) ..... 8
Phishing indicators ..... 8
Conclusion ..... 10
References ..... 10

# Introduction

In today's world, which is becoming increasingly digital, cybersecurity has become an essential need to ensure that the publics' sensitive information, whether financial or identity. Both individuals and organisations have been becoming more reliant on digital services, this can become a major risk for them, as cybercriminals can exploit weaknesses in unsecured networks, authentication systems, human behaviour etc. This report will examine

four key areas of cybersecurity; 2FA/multi-factor authentication, use of public Wi-Fi, phishing/social engineering and safe use of Wi-Fi. This report will aim to investigate different risks posed by threats, preventative measures and indicators to determine legitimacy. By evaluating these different threats and mitigating them, the objective of the report is for the reader to develop an understanding and gain the ability to reduce vulnerabilities and protect themselves against cyberattacks that have been becoming increasingly sophisticated.

# Multifactor Authentication: The Categories, Effectiveness and Trade-offs

## The Categories of authentication factors

In the cyber security guidelines published by the National Institute of Standards and Technology (NIST SP 800-63B) and other sources, authentication methods are split into three categories. They are divided up by what credentials the user provides to have access (Grassi, Garcia and Fenton, 2017; Microsoft, n.d.).

These 3 main categories are something you know, something you have, and something you are. **Something you know** refers to information the user remembers like a password, a numerical PIN or a security question (Grassi, Garcia and Fenton, 2017; Microsoft, n.d.).

Standard passwords alone are risky as they can be exposed through database breaches, brute force attacks, and keylogging (Florczak, Jasiak and Szczygieł, 2023).

**Something you are** covering unique features every human has such as fingerprints, facial recognition or iris scans. This works as they are biological features which are unique to everyone (Florczak, Jasiak and Szczygieł, 2023)..

**Something you have** refers to a user's actual possession that includes physical and digital items, such as authentication apps, a phone, text/email codes as well as hardware security keys (Florczak, Jasiak and Szczygieł, 2023; Grassi, Garcia and Fenton, 2017; Microsoft, n.d.).

To count as multifactor authentication (MFA) a login must require at least two different categories of authentication (Grassi, Garcia and Fenton, 2017). For instance, using two factors from the same category such as a password and a security question is considered multistep single-factor authentication, this is because both factors rely on a memorized secret which share the same risk (Grassi, Garcia and Fenton, 2017).

## Analyzing 2FA/MFA Implementation

Differing secondary verification methods come with different tradeoffs, convenience, and levels of security. **SMS and Email passcodes** are one of the most adopted methods of 2FA as they both are convenient and don’t require the user to install an extra application (Florczak, Jasiak and Szczygieł, 2023). However, they also come up with the most risks as SMS can easily be exploited by SIM swapping which is where a bad actor can trick a phone provider into transferring a number. Other risks include malware, phishing attacks as well as network interception (Florczak, Jasiak and Szczygieł, 2023; TypingDNA, 2025).

**Hardware Security Keys** are physical devices which plug in via USB or NFC use public key cryptography with strict origin binding (Florczak, Jasiak and Szczygieł, 2023; Grassi, Garcia and Fenton, 2017). The keys will check the site's exact domain before sending the log in request. This helps prevent phishing via a fake website such as goog1e.com. If the key detects this it will refuse the user log in (Thomas et al., 2019).

**Mobile Authentication Applications (TOTP)** are applications like Google and Microsoft authenticators they generate local, one-time use passwords without requiring a mobile signal, which in turn removes

the risk of SIM swapping (Florczak, Jasiak and Szczygieł, 2023; Grassi, Garcia and Fenton, 2017). They still have the same risk as SMS and email passcodes and can be entered into phishing websites to compromise said account (Thomas et al., 2019).

## Evidence of Effectiveness

Research shows that having a second authentication factor massively reduces the chances of an account being taken over (Maynes, 2019; Thomas et al., 2019). Microsoft's threat research showed that using any form of MFA stopped over 99.9% of automated account attacks like credential stuffing (where bad actors use automated software to inject stolen usernames and passwords from a data breach into the login pages of other websites (OneIdentity n.d.)) and password spraying (where an attacker tries a single or small list of common passwords across many accounts rather than testing many passwords across a singular account (Bart Lenaerts-Bergmans 2022))(Maynes, 2019; Weinert, Bains and Turner, 2019).

A joint study conducted by Google, NYU and UC San Diego analyzing millions of accounts came to the conclusion that using a secondary possession factor stopped 100% of automated attacks, 99% of bulk phishing campaigns and between 66% and 90% of targeted attacks (Google Security Blog, 2019; Thomas et al., 2019).

## Security Guidance

NIST deems SMS a “restricted authenticator” due to its known security risk. Even with that, security firms still encourage people to use SMS 2FA over relying only on a password for three reasons (Grassi, Garcia and Fenton, 2017; TypingDNA, 2025). The first reason is it helps with stopping automated attacks as they cannot complete SMS prompts automatically which blocks the most common low costing attacks (Google Security Blog, 2019; Thomas et al., 2019). The second reason is the ease of use and adoption, SMS doesn't require a download or setting up a new device making it easy for “non-tech-savvy” users to start using it with little to no setbacks (Florczak, Jasiak and Szczygieł, 2023). The third and final reason is that it increases the time and resources required for bad actors as they would have to carry out a SIM swapping campaign, instead of a bulk automated attack (Thomas et al., 2019).

In europe, regulations like the PSD2 require 2FA for online banking and financial transactions to help the user be better protected (Florczak, Jasiak and Szczygieł, 2023). However, adoption still has its challenges as younger people tend to be more amenable to adopting the changes as older users can be put off by the perceived difficulty and the risk of losing a primary device (Florczak, Jasiak and Szczygieł, 2023).

# Public Wi-Fi

## Public Wi-Fi statistics and introduction

Public Wi-Fi are a very popular and standard in most establishments in the modern day, ((Devasia, 2026)) this study estimates the number of public hotspots in the order of ¨hundreds of millions¨ with the largest proportion of these being distributed in the USA, UK and France as of 2026. Whilst providing convenient free internet access, they also offer potential security risks: a study (Tincher, 2026) reveals that despite 19% of people reporting they have connected to a meliaceous network prior, 71% still believe Public Wi-Fi is safe. Ignorance of the risks opens you to easily preventable cyber-attacks such as packet sniffing.

## Preventative Measures

The first and simplest preventative measure you can take to protect yourself is acquiring a Virtual Private Network (VPN). (Fortinet, n.d.) Estimates 24.7% of Public WiFi utilize Plain-Text data protocols; Plain-Text network traffic can be easily intercepted and read by anyone as it is publicly broadcast with no encryption. A VPN encrypts all network traffic, meaning a hacker would have to decrypt your VPN's security first before reading your network traffic. The benefits of using a VPN heavily outweigh the cyber-dangers lurking thus using one should be a widespread common personal preventative measure.

## Man-in-the-Middle Attacks

A Man-in-the-Middle attack is common attack that involves the victim being deceived by the perpetrator pretending to be a Public WiFi; with this dynamic, the hacker is able to intercept and insert malicious traffic, for example, DNS poisoning. This could mean instead of connecting to ¨facebook.com¨ you are served the IP to ¨faceb0ok.com¨ whom pretends to be the real thing to steal your login information. (Fortinet, n.d.) Suggests the use of a VPN and encrypted DNS to minimize your vulnerability. Encrypted DNS queries are done over the https protocol which is end-to-end encrypted; this makes DNS spoofing harder.

Using https websites over http where possible is a simple yet effective way to protect yourself with end-to-end encryption. The ¨s¨ in HTTPS sands for secure as your network traffic is encrypted with a trusted certificate. This means if given the option, you should always default to using https when given the option. Similarly, when using common popular domains, the lack of https could be an early warning sign for recognizing a malicious

website. (Buxton, 2026) Details that the most common place to find suspicious URLs is in Phishing Emails and Texts; these can be reduced by being mindful what information you share online about yourself and always read and double check a link before clicking on it.

# Phishing/Social engineering

## Defining phishing

According to cloudflare.com, a well-known and reliable source, the core definition of 'phishing' "*refers to an attempt to steal sensitive information by masquerading as a reliable source with a legitimate attempt*" *(CloudflareA1, n.d.)*. This information tends to typically come in the form of the victims' usernames, passwords, bank accounts, addresses or any other important pieces of data which the attacker would typically exploit this information, or sell this information elsewhere (CloudflareA1, n.d).

## Difference between Phishing and other forms of Phishing:

Phishing is the general term for any attempt to manipulate or steal information from victims. Perpetrators tend to use different methods such as smishing, spear phishing and BEC (Business Email Compromise) to do this *(CloudflareA2, n.d)*. However, all of these different methods of stealing information operate under the same umbrella as phishing. Phishing typically only is done through emails; however, attackers have now expanded into different methods such as attack through SMS (smishing), fake QR codes (quishing) and even through phone calls (vishing) *(CloudflareA2, n.d)*.

## Defining Social engineering:

According to a research paper done by the School of Cybersecurity in the University of Chinese Sciences in May of 2020, the definition of social engineering is as follows:

"*In the context of cybersecurity, social engineering is a type of attack wherein the attacker(s) exploit human vulnerabilities by means of social interaction to breach cybersecurity, with or without the use of technical means and technical vulnerabilities.*" *(Wang et al, 2020)*

From this we can determine that human emotions are utilised as a manipulation tactic by the attackers to gain sensitive information from the victim. This is a popular form of

attack which has been utilised since 1984, however has seen much more success since 2008.

## Methods of Attack (Phishing)

This attack is carried out through various methods, such as setting up fake websites that imitate real, well-known websites that are trusted by consumers. This way, the consumers are manipulated by the attacker and in turn, this results in their information being stolen by the attacker. Another form of phishing is smishing. Smishing refers to manipulating the user through SMS (Short Message Service I.E text message) (Wang et al, 2020). This method is popular due to any person being allowed to message another person through SMS. From this its typical for the user to also click the hyperlink as well. From this, attackers would masquerade as social media applications, banks, websites etc encouraging the victims to "verify their identity" (Wang et al, 2020). The goal that the attacker is trying to achieve from this is to gain sensitive information from the victim. However, the difference between this and phishing is phishing is typically done through emails, however smishing is exclusively only done through SMS. *(Wang et al, 2020)*

## Methods of Attack (Social engineering)

Social engineering targets the victim's psychology, making them feel a sense of urgency, fear, etc. This prompts the victim to make irrational decisions instead of rationally trying to determine whether this threat exists or if this is an attempt to gain their information or not. According to a research paper done by the Cybersecurity research centre in London MET University, the process of social engineering focuses on four main stages.

*"The process of social engineering attacks generally consists of four mainstages: information-gathering, establishing a relationship, exploitation, and execution."*
*(M.Zaoui et al, 2024)*

The first stage is the most crucial stage. Gathering information from the victim is key to ensuring that the initial contact is believable by utilising information received from the user beforehand. This is typically done by the attacker doing comprehensive research on the victim through public accessible information. Additionally, the second step is also important, as establishing a relationship with the victim is key to gaining their trust through manipulation tactics. Once some form of relationship has been established, the attacker then begins to exploit the victim, through manipulative tactics and exploitative methods. This stage is where the attacker is attempting to accomplish his

goal, which regularly is to gain the victims sensitive information, where it will either be utilised (e.g. monetary value being drained from an account) or sold. Once this stage has concluded, the final stage, is where the attacker would attempt to cover their track by deleting messages, or any method of communication which was used between the victim and the attacker *(M.Zaoui et al, 2024)*.

### Phishing indicators

According to a thesis which was done in 2022 in the University of Jyvaskyla in Finland, technical indicators that can help to determine if an email can be legitimate or not. Technical indicators to be aware of can be as follows:

- Grammatical errors – Any grammatical errors can be determined as a phishing attempt, as automated messages coming from companies would never have grammatical errors within them, due to the messages being automated.
- Visual deception – Phishing emails tend to use visual deception to create a sense of familiarity as soon as the victim would find the email trustworthy.
- URL obfuscation – The definition of URL obfuscation is as follows; *"disguising URLs to trick the target into connecting to the phisher's proxy server and not the real server."* From this we can determine that a key indicator to be aware of which should help as a guidance should be to be aware of the URL as it may look suspicious.
- SSL Padlock – Another indicator can be SSL Padlocks. When clicking on a URL, ensuring that there is a small padlock on the left-hand side of the URL can allow for us to determine whether this is legitimate or not. If the SSL padlock can be seen on the left-hand side, we can determine this is legitimate, as this means that it is encrypted through

## Safe use of Devices

### Ensuring devices and software are kept current

Keeping your operating systems apps and browsers up to date is essential for protecting your devices from security risks and cyber threats. The following is the list of the principles.

#### Why updates matter

In the sources text (Device security guidance pg.24)

Device security guidance is updated periodically with new functionality and performance enhancements as well as fixes for bugs. Importantly these updates include security fixes that patch up vulnerabilities that attackers could exploit to steal data encrypt files or break Ur device.

## What needs updating

The Device security guidance outlines four areas which will need to be regularly maintained

Operating systems: basic operating software that typically has an automatic system to keep it updated.

Web Browser: highly complex tools that can be attacked by malicious websites and extensions: Additional programs that extend the functionality of a browser.

Third party apps: apps that you have installed may update automatically or be installed manually from the application.

Anti-virus Software: Needs regular updates to be able to download new bug fixes and new signatures for newly detected viruses.

**Device support and Lifecycle**

As noted in the Device security guidance products are only valid for a limited amount of time until they become obsolete. It's important to keep your software and hardware supported by the developers and upgrade to newer versions as soon as you can.

## Managing Automatic Updates and Backups

The original recommendation is to manually check for updates as things can still go wrong when automatic updates are not enabled or when there is insufficient storage or the device does not restart for an update to be installed. To stay safe:

- Make sure to back up files before updating.

Check your update settings to make sure they are functioning correctly and that you have Wi FI power.

- Update tests on a small sample of devices when managing multiple systems but do so in a timely fashion to not leave devices vulnerable to attackers.

According to the Digital Care Hub, device encryption is one of the strongest basic protections as it makes all the data in the device and within its file system unreadable to those who dent have the proper decryption key or user password.

As outlined in the NCSC Small Business Guide, they ensure whenever a mobile device is left unattended in public or shared environments it will not be easily accessed by casual passersby or by anyone that does not know their PIN or password.

Finally based on information from the Northern Irlend Cyber Security Centre Business Security Hub, using a reputable software is an effective way to obtain active protection as it constantly monitors files and network traffic. They can detect known viruses and

warn about suspicious activity as soon as it happens and help you to block and delete malicious files before they could infect your valuable data or cause problems in the way your system operates.

## Risks of Installing Software from Unoffical Sources

According to the cybersecurity breakdowns like the TechSilos Guide on Software Downloads,any software or utility downloaded from unverified or unofficial sources poses great risks due to the absence of official quality and safety validation. The text emphasises that unofficial or pirated installers often include hidden dangers like:

Hackers frequently add spyware to installers to steal passwords and remote-control trojans to the malicious payload.

Compromised supply chains and downloads: malicious actors embedded code in unverified third-party software packages and fake application updates or pirated media files with the user downloading malware.

Taking advantage of unpatched vulnerabilities: cyber actors actively look for and exploit opportunities to gain access to computers running outdated or obsolete software using known vulnerabilities to gain access without requiring the user to act.

### Federal Bureau of investigation:

The FBI has sent out alerts urging consumers to not use free public USB chargers at places such as airports or shopping centres. They explicitly warn against the use of public USB wall outlets for charging personal devices where the intention is to infect them with malware or surveillance tools urging the use of standard ac wall outlets with personal chargers. These alerts from the sources such as CBS News on the FBI Charging Warning and The Guardians report on FBI Warnings.

### Federal Communications Commission:

The FCC maintains consumer guidance warnings regarding highlighting that corrupted public charging ports can allow malicious actors to lock devices, export sensitive data and passwords or transfer malware. To mitigate these risks, the FCC recommends carrying portable external batteries or using a USB data blocker when traveling. Details like this are found directly through recourses tracking government guidance, such as Dark Readings Analysis of FBI and FCC Warnings..

# Conclusion

In conclusion the use of cybersecurity procedures is necessary in protecting both individuals and organisations from an array of emerging online threats. From the above discussions and recommendations, it is evident that incorporating multi factor authentication systems excising caution when connecting to public WI-FI and knowing social engineering methods lower the chances of getting hacked or having any breaches. In addition, adopting proactive measures such as updating software regularly not downloading any software unofficially and watching out for public chargers serve as an effective protective measure against attacks.

Therefore cybersecurity depends largely on technology and high levels of awareness. Although contemporary security systems and encryption methods help protect online activities of user's user knowledge is key. This essay discusses several fundamental cybersecurity issues. Understanding and incorporating core security measures will lower any form of vulnerability and risks involved in the online environment.

# References


Adnan, Wisam & Al-Muswi, Kareem & .(2025) .بابل, ، & المعلومات, جامعة & كلية, تكنولوجيا Assessing the Impact of Phishing Attacks on Organizational Security and Mitigation ..Strategies. 33. 147–155. 10.29196/jubpas.v33i1.5650

*Airaksinen, M. (2022). The State of Phishing: An Analysis on The Indicators of Phishing Attacks.*

Bart Lenaerts-Bergmans (2022) Password Spraying Available at: https://www.crowdstrike.com/en-gb/cybersecurity-101/cyberattacks/password-spraying/ (Accessed: 20 October 2026).

Buxton, O. (2026) *What are malicious websites and how can you protect yourself?* Available at: https://uk.norton.com/blog/malware/what-are-malicious-websites (Accessed: 21 October 2026).

Cloudflare: What is phishing? Accessed at:https://www.cloudflare.com/learning/access-management/phishing-attack/ A1(Accessed: 23 October 2026)

Cloudflare: What is smishing? Available at: https://www.cloudflare.com/learning/access-management/smishing/ A2 (Accessed: 23 October 2026)

Devasia, A. (2026) *40+ Commercial WiFi Statistics for 2026 (Data + Sources)*. Available at: https://thenetworkinstallers.com/blog/wifi-statistics/ (Accessed: 21 October 2026).

Florczak, S., Jasiak, A. and Szczygieł, I. (2023) 'Two-factor authentication (2FA) comparison of methods and applications', Advances in Web Development Journal, 1(3), pp. 26–45.

Fortinet (n.d.) *Man-in-the-Middle Attack: Types And Examples*. Available at:https://www.fortinet.com/uk/resources/cyberglossary/man-in-the-middle-attack (Accessed: 21 October 2026).

Google Security Blog (2019) New research: How effective is basic account hygiene at preventing hijacking?, Google Security Blog. Available at: https://security.googleblog.com/2019/05/new-research-how-effective-is-basic.html (Accessed: 20 October 2026).

Grassi, P.A., Garcia, M.E. and Fenton, J.L. (2017) Digital Identity Guidelines: Authentication and Lifecycle Management, NIST Special Publication 800-63B. National Institute of Standards and Technology, Gaithersburg, MD.

Maynes, M. (2019) One simple action you can take to prevent 99.9 percent of account attacks, Microsoft Security Blog. Available at: https://www.microsoft.com/en-us/security/blog/2019/08/20/one-simple-action-you-can-take-to-prevent-99-9-percent-of-account-attacks/ (Accessed: 20 October 2026).

Microsoft (n.d.) What is Two-Factor Authentication (2FA)?. Available at: https://www.microsoft.com/en-gb/security/business/security-101/what-is-two-factor-authentication-2fa (Accessed: 16 March 2026).

*M. Zaoui, B. Yousra, S. Yassine, M. Yassine and O. Karim, "A Comprehensive Taxonomy of Social Engineering Attacks and Defense Mechanisms: Toward Effective Mitigation Strategies," in IEEE Access, vol. 12, pp. 72224-72241, 2024, doi: 10.1109/ACCESS.2024.3403197.*

OneIdentity (n.d.) What is credential stuffing? Available at: https://www.oneidentity.com/learn/what-is-credential-stuffing/ (Accessed: 20 October 2026).

Thomas, K., Li, F., Zand, A., Zhou, J., Ghasemisharif, M., Solomos, G., Borsos, L., Papp, R., Modersitzki, M., Palmer, N., Matthews, P., Pan, K., Enright, B., Bettini, A., Veicherts, L., Zhao, H., Perrings, B., Adams, A. and Bursztein, E. (2019) 'Strengthening Account Security at Scale with Targeted Interventions', in Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS '19). London, United Kingdom: ACM, pp. 1445–1458.

Tincher, T. (2026) *Public Wi-Fi Statistics: How Do We Use It, and Is It Safe?* Available at: https://www.highspeedinternet.com/resources/public-wi-fi-statistics (Accessed: 21 October 2026).

TypingDNA (2025) NIST SP 800-63B Rev 4: SMS OTP is Now a Restricted Authenticator, TypingDNA Blog. Available at: https://blog.typingdna.com/nist-sp-800-63b-rev-4-sms-otp-is-now-a-restricted-authenticator-but-we-have-the-fix/ (Accessed: 20 October 2026).

*Wang, Zuoguang & Sun, Limin & Zhu, Hongsong. (2020). Defining Social Engineering in Cybersecurity. IEEE Access. 8. 85094-85115. 10.1109/ACCESS.2020.2992807.*

Weinert, A., Bains, S. and Turner, M. (2019) Your Pa$$word doesn't matter, Microsoft Identity Division Technical Report. Redmond, WA: Microsoft Corporation.